Master Direction / Notification header: Title: Master Direction – Cybersecurity and Digital Banking Controls Reference number and date: RBI/DPSS/2026-27/84, dated Feb 28, 2026

The Reserve Bank of India, in exercise of its powers under section 35A of the Banking Regulation Act, 1949, hereby issues the following directions to all Regulated Entities.

1. Applicability and Definitions

1.1 These directions shall apply to all regulated entities, including commercial banks, small finance banks, payments banks and cooperative banks, in respect of their digital banking services and information technology infrastructure.

1.2 “Regulated Entity” means a bank or other entity regulated by the Reserve Bank of India to which these directions apply.

1.3 “Critical System” means any information technology system, application, database, network or service whose compromise, unavailability or unauthorised alteration may materially affect customer transactions, payment operations, regulatory reporting or the continuity of essential banking services.

2. Access Controls and Multi-Factor Authentication

2.1 Every regulated entity shall deploy multi-factor authentication for all internet-facing critical systems, privileged accounts and remote administrative access, within 60 days from the date of these directions.

2.2 The Chief Information Security Officer shall ensure that privileged access rights are reviewed and recertified at least quarterly, with the first review completed within 30 days.

3. Cyber Incident and Fraud Reporting

3.1 Every regulated entity shall establish a central mechanism for identification, classification and escalation of cyber incidents and digital fraud events within 30 days.

3.2 Material cyber incidents and customer-impacting digital fraud events shall be reported to the Reserve Bank through the prescribed reporting channel within 6 hours of detection.

3.3 The Chief Information Security Officer shall submit a consolidated quarterly cyber incident report to the Risk Management Committee within 15 days after the end of each quarter.

4. Board Oversight and Policy Approval

4.1 The Board of Directors shall approve or re-approve the regulated entity’s cybersecurity and digital banking risk management policy within 90 days.

4.2 The Risk Management Committee shall review implementation of the policy and outstanding remediation actions at least quarterly, with the first such report

submitted to the Board within 30 days after the committee meeting.

4.3 The deliverable required under clause 4.2 shall include the status of all material cyber incidents reported under clause 3.2 and all overdue remediation actions.

5. Data Retention and Record-Keeping

5.1 Regulated entities shall maintain audit logs for critical systems, including authentication, privileged access and material transaction events, for a minimum period of 12 months, with the required retention capability implemented within 90 days.

5.2 Records relating to cyber incidents, fraud investigations and regulatory submissions shall be preserved for at least 8 years from closure of the relevant case, with the retention framework operational within 6 months.

6. Third-Party and Vendor Risk

6.1 Before onboarding any service provider with access to a critical system or sensitive customer information, the regulated entity shall complete and document a cybersecurity and operational resilience risk assessment within 30 days of commencement of the procurement process.

6.2 Existing critical third-party arrangements shall undergo such assessment within 6 months, and material deficiencies shall be reported to the Risk Management Committee within 15 days of identification.

7. Customer Communication and Awareness

7.1 Regulated entities shall implement customer awareness measures covering phishing, unauthorised digital transactions, credential protection and safe use of banking applications within 60 days.

7.2 Customer-facing alerts for material cybersecurity incidents affecting digital banking services shall be issued through appropriate communication channels within 24 hours of confirmation, subject to applicable law and investigative requirements.

8. Amendment to Earlier Notification

8.1 In partial modification of RBI Notification No. RBI/2024-25/112, dated December 18, 2024, references to annual cybersecurity access reviews shall stand amended to require quarterly privileged-access reviews as specified in clause 2.2 of these directions.

9. Responsibility for Compliance

9.1 The Chief Information Security Officer shall be responsible for monitoring implementation of clauses 2 and 3 and shall certify compliance to the Board within 30 days after completion of each quarterly review.

These directions shall come into force with immediate effect.